

Dona — Reporte final post-Phase 0

Fecha: 2026-05-01 · HEAD origin/main: 32da747 · Modo: solo lectura. · Sin acciones realizadas en este reporte.

Phase 0 cerrada. Los 3 P0 originales del Plan v2.1 estan mergeados y desplegados: STRIPE_WEBHOOK_SECRET (T0.2, commit 58c806b), META_APP_SECRET (T0.3, f79b069), INBOUND_WEBHOOK_SECRET (T0.4, 32da747). Render verde, WhatsApp/Meta activo, landing carga. Pendientes: T0.10 Whapi sin firma + gap funcional Stripe/backend de creditos.

1. Estado actual de git

- **Rama actual local:** pr/inbound-webhook-secret-obligatorio (HEAD c76219d).
- **Ultimo commit en origin/main:** 32da747 — Merge pull request #9 from celestinojbm/pr/inbound-webhook-secret-obligatorio.
- **git status -sb:** ## pr/inbound-webhook-secret-obligatorio...origin/pr/inbound-webhook-secret-obligatorio (sin cambios pendientes; los untracked son los PDFs/scripts de planificacion generados durante la conversacion).
- **main local:** sigue en f79b069 (post-T0.3) — desincronizado respecto a origin/main (32da747). Los merges de T0.4 ocurrieron en GitHub. No es problema; se alinea con *git checkout main && git pull --ff-only origin main* cuando lo decidas.

Ramas PR locales (9)

```
pr/disclaimer-responsable
pr/docs-housekeeping
pr/inbound-webhook-secret-obligatorio <- rama actual
pr/legacy-inventory
pr/log-sanitization-json
pr/meta-webhook-firma-obligatoria
pr/stripe-webhook-firma-obligatoria
pr/tools-docs-firefly-higgsfield
pr/voice-forward-env
```

Ramas PR remotas (9, mismas)

Las 9 ramas siguen en origin. Todas ya mergeadas en main (cada una corresponde a un PR cerrado en GitHub, no eliminado automaticamente al mergear).

2. Confirmacion de los 3 P0 mergeados

Los 3 fixes estan presentes en origin/main:

PR	Merge commit	Verificacion en origin/main
T0.2 Stripe	58c806b	agent/billing.py:34 'Fail-fast: STRIPE_WEBHOOK_SECRET obligatorio en produccion' + RuntimeError linea 44
T0.3 Meta	f79b069	agent/providers/meta.py:107 'Fail-fast: META_APP_SECRET obligatorio en produccion' + RuntimeError linea 116
T0.4 Inbound	32da747	agent/inbound_tokens.py:32 'Fail-fast: INBOUND_WEBHOOK_SECRET obligatorio en produccion' + RuntimeError linea 41

Imports top-level en agent/main.py (forzar checks al startup):

```
agent/main.py:30 import agent.billing          # noqa: F401 (T0.2)
agent/main.py:35 import agent.inbound_tokens  # noqa: F401 (T0.4)
```

(T0.3 no requirio import top-level — el check vive en el `__init__` de `ProveedorMeta`, que se instancia ya en `main.py:54` cuando `obtener_proveedor()` se invoca.)

3. Resumen de seguridad

3.1 Riesgos P0 cerrados

Riesgo	Antes	Ahora
Acreditacion forjable de creditos via Stripe webhook	Backend /webhook/stripe aceptaba payloads sin firma con warning	Produccion aborta deploy si falta <code>STRIPE_WEBHOOK_SECRET</code> ; runtime rechaza igual (defensa en profundidad)
Inyeccion de mensajes WhatsApp falsos via webhook Meta	<code>_verificar_firma</code> retornaba True sin <code>app_secret</code>	Produccion aborta deploy si falta <code>META_APP_SECRET</code> ; runtime rechaza igual
Tokens inbound forjados (Zapier/Make/n8n) -> mensajes WhatsApp arbitrarios	Fallback derivado de <code>ADMIN_TOKEN</code> o literal publico del repo	Produccion aborta deploy si falta <code>INBOUND_WEBHOOK_SECRET</code> ; <code>_secreto()</code> rechaza con <code>RuntimeError</code> igual

3.2 Endpoints protegidos

Endpoint	Pre-Phase 0	Post-Phase 0
POST /webhook/stripe (backend)	Acepta sin firma con warning	Firma obligatoria en prod
POST /webhook (backend, Meta)	Acepta sin firma con warning	Firma obligatoria en prod
POST /webhook/inbound/{token} (backend)	Token forjable con secret derivado/literal	Token solo verificable con secret real
POST /api/webhook (landing Stripe)	Ya tenia firma obligatoria (! non-null)	Sin cambios — fuera de alcance

3.3 Variables ahora obligatorias en produccion

Tres env vars criticas. Si falta alguna en `ENVIRONMENT=production`, el deploy aborta con `RuntimeError` antes de servir trafico:

Variable	Plataforma	Modulo que la valida
<code>STRIPE_WEBHOOK_SECRET</code>	Render	<code>agent/billing.py</code>
<code>META_APP_SECRET</code>	Render (solo si <code>WHATSAPP_PROVIDER=meta</code>)	<code>agent/providers/meta.py</code>
<code>INBOUND_WEBHOOK_SECRET</code>	Render	<code>agent/inbound_tokens.py</code>

Ya confirmaste las tres seteadas en Render.

4. Estado operativo

4.1 Render

- Ultimo deploy verificado tras merge de pr/inbound-webhook-secret-obligatorio (32da747).
- Las 3 env vars criticas presentes. Sin RuntimeError al startup.
- Web service con Gunicorn 1 worker (ver Dockerfile:12 — sin cambios; pendiente para T4.2 si se escala).

4.2 WhatsApp / Meta

- Provider activo: WHATSAPP_PROVIDER=meta confirmado por vos en T0.3.
- Validacion HMAC X-Hub-Signature-256 ahora obligatoria.
- Replay protection (timestamp window 600 s) ya estaba activa, sigue funcionando.
- Mensajes del owner llegan correctamente (verificado manualmente por vos).

4.3 Stripe landing webhook

- URL configurada en Stripe Dashboard: <https://www.usadona.com/api/stripe/webhook> segun tu reporte previo.
- **Recordatorio del Diagnostico T0.2 corregido:** esa ruta no existe en el repo (existe /api/webhook solo). Si los webhooks estan dando 404 silencioso, el welcome WhatsApp post-pago no se entrega. **No verificado en este reporte** — pendiente operativo (Bloque 1 del Diagnostico T0.2 corregido).

4.4 usadona.com (landing)

- Carga correctamente (verificado por vos).
- Disclaimer responsable (PR4) ya en produccion desde el merge de Phase 0 inicial.
- TS check sin errores nuevos al cierre del ultimo PR.

5. Pendientes restantes

5.1 Seguridad — P0 nuevo (descubierto en T0.3)

T0.10 — Whapi sin firma de webhook. agent/providers/whapi.py no implementa validacion. Si en algun momento WHATSAPP_PROVIDER se cambia a whapi, el endpoint /webhook aceptaria payloads forjados desde cualquier IP. **Hoy no es activo** (provider es Meta), pero queda como deuda P0 para no olvidar al rotar provider o ante un cambio no planificado.

5.2 Housekeeping git

- **9 ramas remotas pr/*** siguen en origin sin borrar despues del merge. No es funcional, pero limpia historia. Borrarlas via UI de cada PR cerrado o `git push origin --delete pr/<nombre>` (uno por uno).
- **9 ramas locales pr/*** tambien siguen. `git branch -d pr/<nombre>` cuando esten mergeadas.
- **main local desincronizado** respecto a origin/main (f79b069 -> 32da747). `git checkout main && git pull --ff-only` para alinear.

5.3 Housekeeping documental

Untracked en working tree (todos artefactos de planificacion generados durante la conversacion, ninguno en codigo productivo):

- 4 PDFs Diagnostico_T0X_*.pdf
- 1 PDF Reporte_PostMerge_*.pdf
- 3 PDFs Resumen_T0X_Implementacion_*.pdf
- 6 scripts generar_*.pdf.py

Convendria un PR pr/docs-housekeeping-2 siguiendo el patron anterior: mover PDFs a docs/auditorias/ o docs/planes/ y scripts a docs/scripts/.

5.4 Gap funcional critico — Stripe / backend de creditos

Identificado en el Diagnostico T0.2 corregido (§3) y aun sin resolver:

Cliente paga \$20/\$40 mensual en Stripe	Estado actual
Stripe cobra al cliente	OK
Welcome WhatsApp se envia	depende de si la URL /api/stripe/webhook resuelve a 404 o a /api/webhook
Creditos acreditados en backend Dona	ninguno
Suscripcion persistida en DB del backend	ninguno
Plan/tier sincronizado en backend	ninguno

El backend Python procesa creditos (agent/billing.py:procesar_evento_stripe) pero **nadie le manda webhooks** porque Stripe esta apuntado al landing. Como el landing tampoco acredita, **los pagos quedan sin contraparte funcional en Dona.**

Esto **no es** un riesgo de seguridad — es un **gap operativo** que afecta la promesa del producto. Es **T1.3** del Plan v2.1 ('Migrar billing a fuente unica backend Python'). Cierre P0 tecnico OK pero gap funcional sigue abierto.

5.5 Phase 1 pendiente del Plan v2.1

Tareas que **no son P0** pero ya estan planificadas:

- **T1.1 / T1.2** — Workspace + resolver telefono -> workspace_id (migracion progresiva).
- **T1.3** — Migrar billing a fuente unica backend (resuelve §5.4).
- **T1.4** — Plan + creditos incluidos + top-ups + Customer Portal.
- **T1.5** — Cifrado A.3 (mensajes, business tables).
- **T1.6** — Audit log append-only.
- **T1.8** — System prompt premium ('lider de operaciones').

5.6 Operativos pendientes (no P0)

- **Verificacion operativa** del Bloque 1 del Diagnostico T0.2 corregido: confirmar URL exacta del webhook Stripe en Dashboard y si los welcome WhatsApp llegan a clientes recientes.
- **Sentry / Variante B de PR1** — observabilidad activa pendiente para T4.4.
- **CI** — GitHub Actions con pytest + lint + typecheck (T4.5).

6. Proximo orden recomendado (sin implementar)

Prioridad inmediata (housekeeping, riesgo cero)

- **Borrar las 9 ramas remotas pr/* mergeadas** desde GitHub UI (cada PR cerrado tiene boton 'Delete branch').
- **Borrar las 9 ramas locales pr/*** y volver main local a origin/main (32da747).
- **Smoke check operacional:** un mensaje WhatsApp de ida-vuelta, una carga de usadona.com, una llamada a /voice/reenviar, una invocacion a GET /admin/inbound/token con generacion de token + POST de prueba al endpoint inbound. Tres minutos.

Prioridad alta (cerrar gap funcional + ultimo P0)

- **Verificar URL del webhook Stripe en Dashboard** (Bloque 1 del Diagnostico T0.2 corregido). Si es /api/stripe/webhook y no existe -> arreglar o cambiar a /api/webhook. **Decision operativa, sin codigo.**
- **T1.3 — Migrar billing a fuente unica backend Python.** Cierra el gap \$5.4. Un cliente que paga \$20/\$40 deberia recibir creditos en el backend. PR de tamaño medio (~100-200 lineas).
- **T0.10 — Whapi firma de webhook.** Hoy no es activo pero deja la deuda cerrada antes de cualquier cambio futuro de provider. PR pequeno (~30 lineas).

Prioridad media (housekeeping documental + Phase 1)

- **PR de housekeeping documental** (pr/docs-housekeeping-2): mover los 8 PDFs y 6 scripts untracked a docs/. Mismo patron que el primer housekeeping.
- **T1.1 / T1.2** — Empezar Workspace + resolver progresivo. Bloqueante para T1.3+ a futuro pero T1.3 puede hacerse antes con telefono directo y migrar despues.
- **Decidir matriz plan ↔ creditos ↔ tools** (T1.4) — bloqueador previo a Phase 1.

Prioridad baja (Phase 4)

- **T4.4** — Sentry + alertas (Variante B del PR1 original).
- **T4.5** — CI GitHub Actions.

Cierre

- Phase 0 (3 P0 originales) **cerrada** en produccion: STRIPE_WEBHOOK_SECRET, META_APP_SECRET, INBOUND_WEBHOOK_SECRET obligatorios y verificados.
- Render verde, WhatsApp activo, landing carga.
- Proximo bloque critico: gap funcional de creditos (T1.3) + housekeeping de ramas.
- T0.10 Whapi queda como deuda P0 conocida pero no activa hoy.

Sin acciones realizadas en este reporte.